YBY V4.1.20 정밀 분석 보고서

회사 업무용 적합성 · 기능 완성도 · 보안 · 자료 보존 · 운영 안정성

> **종합 판단: 사내 카드 관리의 보조 업무 도구로 조건부 시범 운영이 가능합니다. 전사 공식 정산·회계의 단독 원장으로 바로 전환하는 것은 보류를 권고합니다.**

화면과 업무 흐름은 상당 부분 구현되어 있습니다. 서버의 입력 검증, 중복 방지, 정정 이력, 백업·복구 장치도 확인됩니다. 그러나 운영 완성도는 기능 구현 수준보다 낮습니다. 복구 범위, 암호·백업 보호, 관리자 권한 분리, 실제 회사 Windows 환경 확인을 먼저 해결해야 합니다.

분석 기준	내용
기준일	2026년 10월 20일 · 한국시간 기준
분석 대상	사용자가 지정한 V4.1.20 전체 ZIP의 실제 다운로드본
배포 커밋	b3220d0eb3038e6ff3454d552fc11ebe38b16e2c
배포 크기	4,562,841바이트 · ZIP 항목 248개
수행 내용	코드 검토, 패키지 무결성 검사, 전체 자동 검사 재실행, 최신 브라우저 검사, 보안·백업 관찰 시험, 제한적 부하 검사
변경 여부	분석만 수행. 배포 프로그램·회사 운영 자료를 수정하지 않음

이 보고서를 읽는 순서 · 쪽수는 PDF 기준

빠른 의사결정은 2쪽, 업무별 판단은 5~9쪽, 우선 보완 사항은 10~15쪽, 검증 결과와 도입 조건은 17~18쪽을 확인하십시오. 부록에는 재현 조건과 코드 근거를 정리했습니다.

보고서의 “확인”은 명시한 코드·시험 범위 안에서의 확인입니다. 제3자 침투 시험, 실제 회사 운영 승인, 법령·인증 적합성 판정 또는 모든 결함의 부재를 뜻하지 않습니다.

01. 경영·운영 의사결정 요약

사용 가능 여부를 사용 목적에 따라 구분

사용 목적	판단	조건 또는 이유
사내 법인카드 불출·반납 관리	조건부 사용 가능	담당 서버·운영자 지정, 계정별 권한 확인, 백업과 실기 검증 후 시범 적용
사용정산·결재의 보조 대장	조건부 사용 가능	이관완료와 YBY 승인완료를 구분하고 회계 담당자가 금액을 대사
하이패스·유류대카드 배부 관리	조건부 사용 가능	회사 실제 카드 묶음·상태 전이·이력 표시를 업무 담당자가 확인
전사 회계의 유일한 공식 원장	현 상태 도입 보류	회계 마감·전표 대사·세무 통제·복구 목표·감사 통제의 입증 부족
Oracle 자동 수신 시스템	아직 사용 불가	수신함 경계와 매칭 기능은 있으나 실제 연결·조회 SQL·증분 동기화가 없음
인터넷에 직접 공개하는 서비스	현 상태 권고하지 않음	사내망 전제. 원격 접속은 회사가 승인한 VPN 등 별도 접근 통제 필요

정식 업무 적용 전에 우선 해결할 다섯 가지

- 사용자 비밀번호를 최고관리자에게 보여주는 기능을 회사 보안 정책에 맞게 재검토합니다. 권장 방식은 본인만 아는 비밀번호와 관리자 초기화입니다.
- 백업을 암호화된 별도 저장소에 보관하고 보존·삭제·용량 경보를 정합니다. 현재 ZIP은 암호화되지 않습니다.
- 새 Windows PC로 DB·첨부·계정·인증서 신뢰까지 복구하는 시험을 완료합니다. 전체백업 ZIP만으로 동일 접속 환경까지 복원되지는 않습니다.
- 관리자 자기 결재, 관리자 암호 초기화 후 기존 세션 유지, ALL 범위 계정의 전권을 회사가 명시적으로 승인하거나 제한합니다.
- 실제 회사 Windows/Edge/WebView2·보안 프로그램·사내망에서 담당자와 사용자 인수 시험을 수행합니다.

> **권고: 기존 업무 장부와 병행하여 시작하고, 금액·건수·반납·결재 상태를 대조한 뒤 확대하십시오. 자동 검사 364개 통과만으로 전사 운영 승인을 대신할 수는 없습니다.**

02. 분석 범위와 증거의 신뢰도

실제 확인 · 기존 기록 · 미확인을 분리

직접 수행한 범위

- 지정 GitHub 주소에서 ZIP을 다시 내려받아 SHA-256과 ZIP CRC를 확인했습니다. MANIFEST에 기록된 247개 파일의 해시가 모두 일치했습니다.
- 그 ZIP을 별도 폴더에 풀어 서버·DB·권한·인증서·백업·이관·화면 코드를 검토했습니다. 실제 회사 DB나 회사 서버에 접속하지 않았습니다.
- 추출본에서 Python 전체 검사 332개와 Node 검사 32개를 재실행했습니다. 최신 Chromium 화면 시나리오도 다시 실행했습니다.
- 합성 자료로 계정 목록 노출, 재인증 시도 제한, API 카드번호 반환, ALL 범위 권한, ZIP 백업 보호 범위를 관찰했습니다.
- 5,000개 이력·동시 클라이언트 10개·60회 조회의 짧은 로컬 부하 검사를 수행했습니다.

기존 배포 기록으로만 확인한 범위

V4.1.19→V4.1.20 설치·자료 보존, 한글 경로·읽기 전용 원본에서의 실행 폴더 준비, 과거 브라우저 회귀, 원본 Book1.xlsx 대응 결과는 기존 배포 검증 자료를 참조했습니다. 이번 보고서에서는 이 항목을 모두 새로 실행했다고 주장하지 않습니다.

직접 확인하지 못한 범위

회사 실제 Windows와 인증서 저장소, 도메인 정책·방화벽·VPN, 회사 운영 DB 전체, 실제 Oracle 연결, 다일간 연속 운영, 전원 차단·디스크 고장, 대규모 쓰기 경합, 제3자 침투 시험은 미확인입니다. CI 설정 파일은 있으나 GitHub Actions의 실제 성공 이력까지 검증한 것은 아닙니다.

실행 환경	이번 검토 환경
서버·DB	Linux · Python 3.12.14 · SQLite 3.53.1
프런트엔드	Node.js 24 · Chromium / Playwright
암호화	cryptography 50.0.0 · Windows DPAPI는 코드 검토만 수행

SHA-256: 5217558213f49dc9888fae229fe6512b8b90f8ea4f5073f3133165fb527c9c2e

이 보고서는 개발 이력과 기존 검증 기록도 활용한 기술 검토이며, 독립된 외부 감사기관의 보증 보고서는 아닙니다.

03. 프로그램의 방향과 구조

단일 서버를 기준으로 지점별 업무를 통합하는 경량 시스템

YBY의 방향은 흩어진 카드 불출·반납·사용정산·문서 결재와 하이패스·유류대카드 배부를 한 서버에서 관리하는 것입니다. Excel 과거 자료를 보존해 이관하고, 향후 Oracle 문서를 받아 수동 확인 후 연결하는 방향은 현업 관리 도구로 적절합니다.

> **Windows 실행 → 사용자 전용 실행 폴더 → Python HTTPS 서버 → 서버 측 검증·트랜잭션 → SQLite DB / 첨부 저장 → 지점별 화면·통계·내보내기**

계층	확인한 구현	평가
실행·설치	RUN_LAN_WINDOWS.bat, windows_bootstrap.py, run_ready.py	사용자 경로·패키지 해시·중복 실행·기존 DB 보존 고려
통신·로그인	사설 CA 기반 HTTPS, Windows 로그인 창, 서버 세션	사내망 사용에 맞는 구조. PC별 신뢰 등록·서버 가동 필요
업무 처리	operations.py + domain.py + 업무 모듈	전용 API로 불출·반납·승인·정정 검증
보관	SQLite 레코드별 JSON, 외부 수신·매칭·중복 등록 테이블	기능 확장은 쉽지만 조회·쓰기는 전체 상태 처리 비중이 큼
화면	templates/index.html + static 모듈	업무 화면 풍부. 큰 단일 HTML의 유지보수 부담 존재
복구	DB 온라인 백업, 첨부·키 ZIP, 검증·오프라인 복원	업무 자료 복원 기반은 있음. PC·인증서 복구와는 별도

구조적으로 잘된 점

브라우저 자료만 믿지 않고 서버가 권한·금액·날짜를 검사합니다. requestId 영수증으로 재전송 중복을 막고 revision으로 동시 수정 충돌을 검출합니다. 일반 저장 경로로 완료 이력을 마음대로 덮어쓰지 못하게 제한하며, 이관 수기 정정은 별도 API와 사유·비밀번호 확인을 사용합니다. [E03~E06]

구조적 한계

단일 PC·단일 프로세스·SQLite와 사용자 로그인 계정에 운영이 집중됩니다. 이 구조 자체가 업무용 사용 불가를 뜻하지는 않습니다. 다만 고가용성, 장기 대용량, 직무 분리, 운영 자동화까지 확보한 전사 플랫폼과는 수준이 다릅니다.

04. 기능별 완성도 판단

완성도 백분율 대신 실제 기능과 운영 조건으로 평가

영역	확인한 기능	현재 판단
카드 등록	신용/체크, 국내/해외겸용, 지정 사용자, 목록·출력	주요 기능 구현. 지점 마스터 고정, 민감 정보 최소화 보완
불출·반납	신청일·신청자/실사용자, 상태·이력, 사용/미사용 반납	주요 흐름 구현. 회사 예외 시나리오 인수 시험 필요
사용정산·결재	건별 명세 합계, 승인/반려, 승인취소·정정·재보고	기능 구현. 자기 결재 허용 등 통제 정책 확정 필요
이력대장	입력순 번호, 작성기준일, 입력경로, 열별 필터·맞춤/스크롤	최근 요청 기능을 실제 브라우저로 재확인
Excel 대량 이관	미리보기·행 선택·검증·중복·직접 이력 반영·수기 정정	과거 자료 이관에 활용 가능. 회계 대사·원본 관리 필수
외부 문서 매칭	신청/정산 1:1 연결, 수신 상태, 저장 전 수정·이력	정규화 수신 자료 기준 구현. Oracle 실제 수신은 미구현
하이패스·유류대	별도 카드번호 묶음, 임시/확인, 배부 상태·수정 이력	주요 기능 구현. 차량·사용자·실물 카드 대조 필요
내부 보고·공지	결재선, 정산 복사 초안, 공지·첨부·열람	주요 기능 구현. 보존·악성 첨부 통제 보완
메신저·개인 메모	채팅·쪽지·첨부·가림 UI	협업 편의 기능. 화면 흐림은 접근 통제와 다름
통계·내보내기	조회 결과 집계, 통합 통계, XLSX·인쇄/PDF	관리 자료로 적합. 외부 회계 수치와 일치 보증은 아님
백업·운영	검증·복원·실행 진단·접속 확인	기반 있음. 별도 보관·운영 감시·새 PC 복구는 조건부

평가: 업무 기능은 시범 운영을 검토할 수준입니다. 기업 운영·보안·감사 통제는 보완 단계입니다. 기능 수와 테스트 수로 “완성도 95%” 같은 수치를 산정할 근거는 없습니다.

05. 법인카드·정산 업무의 강점과 주의점

자료 등록과 실제 승인·회계 확정을 구별

잘된 점

- 신청자와 실제 카드 사용자를 구분하고 신청일·반납예정일·실제 불출/반납 이력을 남깁니다. 카드 상태를 일반 화면 저장으로 임의 전환하지 못하도록 서버가 제한합니다.
- 정산 건별 명세는 1~100건, 수량×단가와 합계를 서버에서 검증합니다. 원화 정수 금액을 쓰므로 일반적인 소수점 부동 오차를 피합니다.
- 승인 취소는 원 승인 내역을 보존하고 사유·새 재보고 대기 건을 생성하는 방식입니다. 단순한 마이너스 승인 행만 추가하는 구조보다 추적이 쉽습니다.
- 불출 완료와 반납·정산 상태를 구별하고, 이관 완료 자료는 YBY 승인완료로 임의 변경하지 않습니다. [E04~E07]

보완할 점

현재의 "정산"은 카드 사용 설명과 결재·대장을 관리하는 업무 개념입니다. 카드사 청구 명세 대사, 회계 전표 확정·마감, 부가세/환율 처리, ERP 전송·취소 통제까지 확인한 것은 아닙니다. 이 기능이 필요한 회사에서는 별도 명세와 회계 승인 절차가 필요합니다.

주의 항목	업무 영향	권고
해외겸용 카드 표시	카드 속성 표시와 외화 정산 지원은 서로 다름	원화 환산액·환율·통화가 필요한지 별도 확정
관리자 자기 승인	기능 요구에는 부합하나 직무 분리가 약해짐	예외 승인 사유와 사후 독립 점검, 금액별 정책
미사용·금액미기재·금액0원	같은 의미로 합치면 사용금액·건수 왜곡	담당자용 상태 정의서와 월말 미확인 목록
증빙과 실제 결제	화면 입력만으로 실물 결제가 검증되지는 않음	카드사 명세·증빙과 월별 대사
정정과 승인 취소	원본 수정과 새 승인 흐름을 혼동할 수 있음	업무별 정정 권한·사유·재승인 기준 공지

핵심 인수 시험: 정상 불출→사용 반납→건별 정산→승인→취소→정정→재보고→재승인을 한 건의 추적 화면과 합계에서 대조합니다. 미사용·반려·분실·지연 반납의 실제 회사 처리 기준도 함께 확인하십시오.

06. Excel 대량 업로드와 두 대장의 정합성

최근 문제 영역을 중심으로 재검사

현재 구현의 의미

과거 완료 자료를 올리는 직접 이관은 한 행을 사용정산 이력 1건과 불출 이력에 반영하고, 원본 반납일이 있으면 반납 이력도 생성합니다. 실제 현재 카드의 대여 상태나 YBY 승인 절차를 임의로 완료시키지 않습니다. 신청서·정산서 수신함 방식은 별도 흐름입니다.

검증·보존 장치	평가
파일·구조 제한	xlsx만 지원. 최대 1MB·2,000행, 압축 해제 크기 20MB 등 제한. 매크로·외부 시트·특정 XML 선언을 거부
금액·결측값	양수/0/미기재를 구분. 월 한도·잔여 금액을 사용금액으로 대체하지 않음
카드 연결	끝 4자리는 전체 카드번호로 만들지 않음. 지점·실제 카드 확인 필요
중복·재시도	원본 식별·내용 해시·등록부·작업 영수증으로 재업로드와 응답 유실에 대응
대장 연결	입력경로·작성기준일·입력순 번호·업로드 한정 조회와 양쪽 이력 연계
수기 정정	사용 여부·반납일·부서·진행상태를 사유·비밀번호·버전 확인 후 연결 이력에 반영

이번 브라우저 재검사에서 확인한 것

두 대장의 모든 열 필터(정산 15개·불출반납 18개), 정확 일치 선택과 직접 입력, 사용/미사용 구분, 빈값, 지점 격리, 상단 정정 도구, 실제 XLSX 상태 문구, 화면 맞춤/스크롤, 완료 후 행 제거와 초기화, 지연 응답·저장 중 초기화 차단을 확인했습니다. JavaScript 실행 오류는 없었습니다.

남는 업무 위험

내용 기반 중복 방지는 모든 원장 체계에서 통용되는 거래 고유번호를 대신하지 못합니다. 실제로 서로 다른 두 건의 값이 같으면 중복처럼 보일 수 있고, 원본 금액·부서가 바뀌면 충돌 검토가 필요합니다. 가능하면 외부행ID를 고정하고 업로드 전후 원본 행수·건수·합계·미기재·반납 건수를 대조하십시오. [E07~E09]

원본 Book1.xlsx 4행→정산4·불출4·반납3·금액미기재3·합계225,000원 결과는 기존 배포 검증 기록입니다. 이번 보고서 공개 파일에는 원본 Excel·개인정보를 포함하지 않았습니다.

07. Oracle 외부 자료 연계의 준비 수준

수신함·매칭이 있다는 것과 실제 DB 연결은 다름

> **현재 Oracle 실시간 연동은 완성되지 않았습니다. external_documents.py는 “No Oracle connection or source SQL yet”라고 명시하며, 정규화 자료의 저장·조회 경계를 제공합니다.**

이미 마련된 부분

- 신청서와 정산서를 독립 문서로 저장하며 외부 문서 키·리비전·원본 결재 상태·지점을 보존합니다.
- 수신 확인과 실제 업무 적용을 구별하고, 각 문서의 1:1 매칭·수정·해제·변경 이력을 관리합니다.
- 저장 전 매칭 수정은 가능하고, 반납·정산으로 사용된 연결은 기존 정정 절차를 따르도록 제한합니다. 외부 결재 상태는 참고로 두고 YBY 결재를 별도로 진행하는 구상과 맞습니다. [E10]

실제 연동에 반드시 필요한 나머지

필요 사항	완료 판정 기준
DB 담당자 제공 뷰/SQL·자료 사전	신청·정산 문서 키, 지점/부서, 사용자, 금액, 카드 끝자리, 결재·회수·삭제 상태의 대응 확정
읽기 전용 접속·비밀 관리	최소 권한 Oracle 계정, 제한된 망 경로, 비밀번호 별도 보관
증분 수신·재처리	수정 시각과 고유키 기준 수신 위치 보관, 중단 후 재개, 반복 수신 중복 방지
변경·철회 처리	외부 승인 변경·문서 취소·지점 변경을 덮어쓰지 않고 검토
모호한 카드·지점	같은 끝 4자리·알 수 없는 부서를 검토 대기시키는 규칙
장애 감시	마지막 성공 시각, 지연·오류 알림, 재시도·운영 담당자 지정

지점 분류의 실제 제약

현재 서버 지점 목록은 본사·서울·인천·정봉·임원실 5개로 고정되어 있으며 광주는 없습니다. 화면에도 같은 고정 목록이 있습니다. 회사의 모든 지점을 담았다고 볼 수 없습니다. 팀/실 단독 표기는 본사로 처리하자는 업무 규칙도, 실제 Oracle 부서코드와 매핑해 오분류 여부를 검증한 뒤 적용해야 합니다. 미확인 소속은 자동 본사 확정보다 검토 대기가 안전합니다. [E04, E11]

08. 하이패스·유류대·보고·협업 평가

기능의 편의성과 업무 통제의 역할을 함께 평가

영역	잘된 점	보완할 점
하이패스·유류대 묶음	별도 번호를 한 묶음으로 관리, 중복 검사, 전후 변경 스냅샷	묶음 수와 카드 실물 수를 구별하고 실제 배부 대장과 대사
배부 상태	대기·불출·회수중·회수완료와 확인 상태를 구분	전입·전출·차량 교체·재배부 기준을 회사 규정으로 정의
수정·삭제	현재 비밀번호·사유·버전 확인과 변경 문서	실물 회수 없이 삭제해도 되는지 권한·보존 정책 확인
내부 보고	정산 원본 복사 초안, 결재선, 자기 검토/최종 승인 기록	정산 원본과 보고서 복사본은 이후 값이 다를 수 있음. 원본 시점 표시·대조 필요
공지·첨부	등록자·권한 확인, 게시 참조 파일만 다운로드 허용	문서 보존기간·파일 검사·용량 관리
메신저·화면 흐림	수신 대상별 열람 제어, 화면 노출 완화 UI	화면 흐림은 암호화·권한·운영체제 잠금을 대체하지 않음

통계와 보고서

개인·지점·부서·목적·전체 집계와 조회 결과 내보내기는 관리자의 일상 확인에 도움이 됩니다. Excel 수기 이관과 정상 승인 건, 승인취소·재보고, 미사용·미기재를 섞어 해석하지 않는 것이 중요합니다. 실제 월간 보고서에서 사용 건수 정의와 승인 금액 정의를 회계 담당자가 합의해야 합니다.

디자인·사용성

최근 대장 화면은 맞춤/스크롤, 좁은 화면 세로 기록, 열별 필터, 상단 정정 도구로 조작성이 개선되었습니다. 반면 18열 대장과 많은 상태·동작은 초보 사용자에게 부담이 될 수 있습니다. 자주 쓰는 열 중심의 기본 보기, 역할별 안내, 미확인/오류만 모아 보기, 화면 확대·키보드 이동 점검을 권고합니다. 접근성 인증 시험은 수행하지 않았습니다.

정상 저장뿐 아니라 취소·반려·재보고·복구를 포함하는 짧은 사용자 매뉴얼을 마련하면 기능 완성도가 실제 업무 효율로 이어집니다. [E12, E13]

09. 보안 기반에서 잘 구현된 부분

보안 장치가 존재한다는 근거와 그 한계

영역	확인 내용	근거
통신	사내망은 HTTPS 요구. 평문 GET은 HTTPS 이동, 평문 로그인 POST는 거부	E01, E14
비밀번호 검증	개별 salt + PBKDF2-SHA256 600,000회. 신규 비밀번호 10~128자 검사	E02
초기 계정	최초 임시 비밀번호 무작위 발급·변경 요구. 고정 공용 초기 비밀번호를 전제로 하지 않음	E01
로그인 시도	동일 IP·계정 5분 10회, IP 전체 100회 실패 제한	E01 app.py:807
세션	난수 토큰, HttpOnly·SameSite=Strict, HTTPS Secure 쿠키, 기본 유휴15분/절대8시간	E01 app.py:598
요청 경계	다른 Origin 요청 거부, 요청 크기 제한, 서버 입력 검증	E01 app.py:785, E04
지점 경계	서버에서 지점 자료·권한 필터, 전용 업무 API 검증	E01 app.py:360, E03
중요 작업	백업·비밀번호 열람·일부 정정/삭제 시 현재 비밀번호 재확인	E03, E07, E15
완료 기록	정산·불출 이력 일반 저장 위조/덮어쓰기 차단과 전용 정정 기록	E04, E07
파일·출력	다운로드 권한·nosniff, XLSX 문자열을 수식으로 만들지 않음	E03, E16

과장해서는 안 되는 부분

로그인 보안과 비밀번호 열람 저장소는 별개입니다. 검증용 해시가 강해도, 현재 비밀번호를 복원할 수 있게 보관하는 기능이 있으면 관리자·서버·백업 유출의 피해 범위는 커집니다. HTTPS 역시 서버 디스크·내보낸 파일·다운로드한 백업을 암호화하지 않습니다.

MFA·회사 SSO, 중앙 보안 감시, 침해 대응 자동화, 인증서 배포의 회사 정책 적합성은 확보되었다고 볼 수 없습니다. 아래의 개선 항목은 보안 장치가 전혀 없다는 뜻이 아니라 기업 운영 기준에 맞춘 추가 통제 요구입니다.

10. 우선 보완 F01 — 비밀번호와 재인증

높음 · 정책상 위험 + 재현한 통제 공백

확인 사실

로그인 비밀번호는 검증용 해시 외에 복원 가능한 암호문으로도 저장됩니다. Windows는 해당 Windows 사용자 DPAPI, 비 Windows는 Fernet를 씁니다. ALL 범위 계정은 본인 비밀번호로 재인증한 후 다른 사용자의 현재 비밀번호를 API로 받아볼 수 있습니다. 조회 이력이 남고 화면은 30초 후 숨깁니다. 이는 이전 기능 요구를 반영한 구현입니다. [E15]

업무·보안 영향

최고관리자나 서버 실행 계정이 침해되면 다른 사용자 비밀번호와 행위의 신뢰도까지 영향을 받을 수 있습니다. 같은 비밀번호를 다른 회사 서비스에 재사용했다면 피해가 확대됩니다. 30초 표시 제한은 이미 열람·복사된 비밀번호를 회수하는 장치가 아닙니다. 사용자의 현재 비밀번호를 알아야 계정 관리가 가능한 것은 아닙니다.

추가 확인: 재인증 실패 제한이 공통으로 적용되지 않음

로그인과 비밀번호 열람에는 제한이 있지만 /api/verify-current-password는 별도 실패 횟수 제한 없이 해시 검증을 수행합니다. 이미 로그인한 합성 계정으로 틀린 비밀번호를 6회 연속 전송하면 모두 403이며 제한 응답은 없었습니다. 단 6회로 대규모 공격 성공을 입증한 것은 아니지만, 이 경로에 공통 제한 코드가 없는 점은 확인했습니다. [E01 app.py:880]

권고 수정

- 정식 업무용 기본값은 비밀번호 표시·복원 저장을 사용하지 않고, 관리자 초기화→사용자 변경 방식으로 전환합니다. 기존 저장 암호문·키는 정책에 따라 정리합니다.
- 모든 재인증 경로에 계정·세션·IP별 제한, 잠시 대기, 감사 기록을 공통 적용합니다. 관리자에게는 MFA/SSO를 중장기 검토합니다.
- 관리자 암호 초기화 후 기존 세션을 보존하는 현재 동작은 편의성 요구입니다. 침해 대응 시에는 세션 강제 종료를 함께 실행하도록 절차화하고 자동 종료 옵션을 둡니다.

완료 기준

일반 로그인·기존 해시 검증은 유지되고 타인 비밀번호 조회는 불가해야 합니다. 재인증 반복 실패에 지연/429가 적용되고 정상 사용자가 복구할 수 있어야 합니다. 계정 침해 시 기존 세션 종료까지 확인하십시오. 비밀번호 열람을 유지한다면 회사 책임자의 위험 수용과 별도 예외 통제가 필요합니다.

11. 우선 보완 F02 — 디스크·백업·민감 정보

높음 · 직접 재현한 보호 범위의 한계

확인 사실

DB는 일반 SQLite이며 업무 데이터와 카드번호를 담습니다. 최신 보조 스냅샷은 JSON입니다. 전체백업 ZIP은 체크섬 검증은 하지만 암호화하지 않습니다. 비Windows에서는 비밀번호 보관용 Fernet 키도 같은 ZIP에 포함됩니다. 합성 자료 시험에서 ZIP만으로 DB를 읽고 그 키로 저장 비밀번호를 복호화할 수 있음을 확인했습니다. 비밀번호 값 자체는 공개 시험 결과에 기록하지 않았습니다. [E05, E15]

> **Windows DPAPI와 Linux Fernet를 구별해야 합니다. Windows 백업 ZIP 하나만으로 비밀번호까지 해독된다고 결론 낸 것은 아닙니다. 다만 두 환경 모두 업무 DB·첨부를 담은 ZIP 자체는 암호화되지 않습니다.**

카드번호 표시와 API의 차이

일부 대장 화면은 카드 끝자리로 가리지만, 해당 지점 카드 열람 권한이 있는 계정의 /api/state에는 전체 카드번호가 전달됩니다. 이는 무권한 지점 침범이 아니라, “화면에서 가렸으니 전체 번호가 클라이언트에 없다”고 이해하면 안 된다는 의미입니다. 카드 전체번호가 필요한 역할과 내보내기 범위를 정해야 합니다. [E01 app.py:360, E13]

권고

- 서버 디스크 암호화와 Windows 파일 ACL을 IT 담당자가 확인합니다. POSIX chmod만으로 Windows 세밀한 ACL 보호를 입증할 수 없습니다. 인증서 폴더는 별도 icacls 규칙이 구현되어 있습니다.
- 백업을 암호화된 별도 저장소로 전송하고, 복호 키는 백업과 분리해 관리합니다. 다운로드 폴더·USB·개인 클라우드에 평문 ZIP이 남지 않게 합니다.
- DB·스냅샷·첨부·내보낸 XLSX/PDF·로그에 대한 보존 기간, 접근자, 폐기 절차를 정합니다. 개인정보와 카드 정보는 실제 필요한 항목만 수집합니다.
- 전체번호 반환·출력을 역할별로 제한하고 마스킹된 조회를 기본값으로 검토합니다.

완료 기준

서버 분실·백업 파일 유출 가정에서 업무 데이터를 보호하고, 권한 없는 사용자는 백업·키에 접근하지 못해야 합니다. 승인된 복구 담당자는 별도 키로 실제 복구할 수 있어야 합니다. 체크섬은 손상 탐지 수단이며 출처 서명·암호화를 대신하지 않습니다.

12. 우선 보완 F03 — 복구·백업 운영

높음 · 자료 백업과 서버 전체 복구의 차이

잘된 점과 빠진 범위

전체백업은 SQLite 온라인 백업·무결성 검사, 첨부 복사, 파일별 해시를 포함합니다. 복원 시 경로·중복·심볼릭 링크·크기를 검사하고, 기존 data를 별도 보존한 뒤 교체합니다. 반면 ZIP에는 certificates, lan_settings.json, 프로그램 본체, Windows 인증서 저장소의 CA 개인키·사용자 DPAPI 프로필이 포함되지 않습니다. [E05, E06, E14]

따라서 같은 PC의 업무 자료 복원과, 고장난 PC를 새 Windows PC로 교체한 뒤 같은 로그인·신뢰 환경까지 복구하는 일은 다릅니다. DPAPI 암호문은 다른 Windows 사용자에서 열리지 않을 수 있으며, CA 개인키가 없으면 기존 CA로 서버 인증서를 갱신할 수 없습니다. 비밀번호 초기화·다시 로그인, 새 CA 등록 또는 별도 안전한 CA 복구 절차가 필요합니다.

동일 디스크 백업·증가량 문제

자동 백업은 쓰기 전에 시도하며 일반 작업은 최소 300초 간격으로 제한합니다. 하지만 백업 ZIP과 DB를 같은 서버 경로에 쌓고, 백업 파일의 자동 보존 개수·기간 제한은 확인되지 않았습니다. 서버 로그의 회전과 백업 보존 정책은 서로 다릅니다. 자동 백업 실패는 경고를 남기고 일부 업무 저장은 계속 진행합니다. [E01 app.py:329]

용량 경계에도 주의가 필요합니다. 첨부 업로드는 누적 2GB까지 허용하지만 복원 검증은 압축 해제 전체 2GB를 상한으로 둡니다. 첨부가 한도에 가까우면 DB·키·메타데이터를 더한 백업이 복원 한도를 넘을 수 있습니다. 이는 코드 상한 비교로 확인한 잠재 불일치이며 2GB 실파일 복구 시험은 수행하지 않았습니다. 생성·검증·첨부 한도를 일관되게 맞추고 여유를 두어야 합니다. [E03 operations.py:375, E05 backup_manager.py:48]

용량 예: DB 크기를 D, 전체 ZIP을 Z라 하면 8시간 동안 5분마다 쓰기가 있는 경우 약 96×(D+Z)가 하루에 추가될 수 있습니다. 실제 횟수·압축률·중요 작업에 따라 달라지는 산식이며 실측 용량은 아닙니다. 첨부가 늘면 반복 전체 ZIP 비용도 증가합니다.

권고와 완료 기준

- 업무일 종료 후 자동 별도 보관, 암호화, 보존·삭제, 실패·여유공간 경보를 운영합니다. 단순히 프로그램 폴더만 복사하지 않습니다.
- 현재 ZIP·DB 백업과 접속 환경 복구 자료를 구분합니다. 인증서 개인키 백업은 클라이언트 배포물과 분리해 제한된 담당자가 보호합니다.
- 새 PC 복구 연습으로 건수·합계·첨부·계정·중복 등록부·수기 정정·하이패스 상태를 대조하고, 접속 인증서 신뢰와 권한까지 확인합니다.
- 목표 손실 허용량(RPO)과 복구 시간(RTO)은 회사가 정하고 실제 시간을 측정합니다. 현재 코드만으로 몇 분 이내 복구를 보장할 수 없습니다.

13. 우선 보완 F04 — 가용성·성능·용량

중간~높음 · 단일 서버 운영의 한계

확인한 구조

HTTP 작업자는 최대 16개, 대기 슬롯은 32개입니다. 주요 업무 변경은 프로세스 전역 잠금으로 직렬화하고 현재 상태를 읽어 검증·저장합니다. DB는 레코드 테이블을 갖추었지만 storage.read는 여러 업무 목록 전체를 읽으며 write도 전체 목록을 비교합니다. 화면은 기본적으로 2초마다 상태 확인을 합니다. 변경이 없으면 작은 응답을 반환하는 최적화가 있습니다. [E03, E06, E13]

이번 제한적 부하 검사 결과

조건/지표	측정값
범위	5,000 이력 · 동시 조회 클라이언트10 · 총60회
성공	60/60
응답시간	중앙값312.79ms · 95백분위1,259.33ms · 최대1,617.99ms
전체 상태 최대 응답	1,253,699바이트
변경 없음 응답	최대116바이트
해석	로컬 단기 조회 기준. 실제 Windows·사내망·동시 쓰기·장기 성능 인증 아님

운영 영향

서버 창 종료, 사용자 로그오프, 재부팅·절전, 디스크 문제는 접속 중단으로 이어질 수 있습니다. 이번 패키지의 권장 실행 경로는 콘솔 기반이며 중앙 서비스 감시·이중화가 확인되지 않습니다. 많은 이력과 첨부·동시 저장에서는 전체 상태 처리와 백업 때문에 지연·충돌이 늘 수 있습니다. 슬롯 제한은 자원 고갈을 줄이지만 사용 인원 보장 수치는 아닙니다.

개선 방향

- 지정 업무 PC 또는 회사 관리 서버에서 운영하고 절전·재시작·보안 업데이트·실행 계정·서버 종료 권한을 관리합니다. Windows 서비스/작업 스케줄러 전환은 별도 검증 후 적용합니다.
- 조회는 서버 페이지 처리·기간/지점 인덱스·필요 필드 API로 옮기고, 업무 단위 DB 변경으로 전체 상태 비교를 줄입니다. 현재 일부 페이지 API가 있어도 화면 전체 상태 동기화가 사라진 것은 아닙니다.
- 실제 예상 자료량과 조회+불출+반납+승인+이관+백업 혼합 부하를 측정합니다. 회사가 정한 허용 응답시간·오류율·복구 기준으로 용량을 확정합니다.

14. 우선 보완 F05~F08 — 권한·감사·파일·유지보수

정식 업무 전 정책과 코드 개선을 함께 진행

ID·우선도	확인 사실·영향	권고·완료 기준
F05 높음 관리자 통제	scope=ALL이 실질적 최고권한입니다. 메뉴 권한이 비어도 전체 자료를 조회합니다. 본인 최종 승인도 허용되고 자기 승인 표시는 기록됩니다. 이는 권한 상승 공격을 입증한 것이 아니라 설계된 전권 범위입니다.	ALL을 최소 인원에만 부여하고 업무 관리자·계정 관리자·승인자·백업 담당자 역할을 분리합니다. 자기 승인 예외와 사후 독립 점검을 문서화합니다. [E01,E03]
F06 중간 감사·기록 수명	주요 업무 변경은 DB 감사와 함께 원자 저장됩니다. 일부 별도 audit() 실패는 출력 후 계속하며 감사 DB도 같은 서버에 있습니다. 외부 변경 불가 보관·정기 검토·보존 자동화는 미확인입니다.	중요 감사 실패 알림과 외부 제한 저장소 전송, 보존·열람 권한을 둡니다. OS 관리자까지 포함한 변조 불가성을 현재 로그만으로 주장하지 않습니다. [E01,E03]
F07 중간 첨부 통제	파일당20MB·누적2GB 제한, 권한·nosniff·안전한 다운로드가 있습니다. 업로드 API의 확장자/실제 형식 허용 목록·악성코드 검사는 확인되지 않습니다. MIME은 파일명 추정입니다.	회사 허용 형식과 파일 서명 검사·백신/격리·오류 안내를 추가합니다. 자동 실행 취약점을 입증한 것은 아닙니다. 다운로드 후 사용자 실행 위험을 관리합니다. [E03]
F08 중간 배포·공급망	파일 해시·PowerShell BOM 검사·라이브러리 고정·라이선스 고지는 장점입니다. 큰 단일 HTML, 구버전 도구·문서, 미사용 xlsx0.18.5도 포함됩니다. 전자서명·SBOM·정기 취약점 점검은 미확인입니다.	미사용 라이브러리·레거시 진입점 정리, 자산 목록·출처·버전·서명/고정 해시 배포, 정기 의존성 점검을 운영합니다. 특정 CVE의 실행 가능성은 이번에 판정하지 않았습니다. [E11,E17]

추가 개선 사항

로그인 전 계정 선택 목록과 /api/bootstrap에서 활성 사용자 이름이 공개됩니다. 합성 3계정 시험도 200 응답으로 확인했습니다. 편의성 선택이라도 임직원 계정 공개 범위를 회사가 결정해야 합니다. CSP에는 unsafe-inline이 남아 있어 스크립트 주입 방어층을 더 강화할 여지가 있으나, 이번에 실제 XSS 공격 성공을 확인한 것은 아닙니다. [E01]

15. 완성도·유지보수성의 최종 평가

업무 기능 완성도와 운영 성숙도를 별도로 판단

평가 축	판단	판단 이유
업무 흐름	구현 수준 양호	등록→불출→반납→정산→결재→취소/재보고와 추적 기반 존재
자료 정합성	강점 있음	서버 검증·트랜잭션·재전송 방지·충돌 검출·원본 보존·정정 이력
화면·사용성	개선된 상태	톤·표·필터·맞춤/스크롤·명세/정정 구조 개선. 장문·다열 화면 교육 필요
접근 보안	기본 장치 있음·기업 통제 보완	HTTPS·세션·지점 격리 구현. 복원 암호·ALL 전권·재인증 제한 등 보완
백업·복구	자료 복구 기반 있음·운영 미완	ZIP 검증·복원 구현. 외부 보관·보존·PC/인증서 복구 별도
운영 안정성	통제된 시범 운영 수준	단일 서버, 수동 실행·감시, 장기 혼합 부하·실제 회사 환경 미확인
확장성	현재 규모 검증 필요	전체 상태·전역 잠금·고정 지점 목록, 신규 대량 자료 증가 대응 필요
Oracle·회계 통합	준비 단계	수신함·매칭과 실제 DB/ERP 통합을 구분해야 함
개발 관리	검사 기반은 강점·체계화 필요	자동 검사 다수. Windows 실기·보안 검토·릴리스 승인·운영 책임 필요

설계상 좋은 선택을 유지할 부분

원본과 정정본 분리, 잘못된 값의 묵시적 0원 변환 금지, 이관완료와 승인완료 구분, 동일 작업 중복 방지, 타 지점 자료의 서버 차단, 기존 DB를 보존하는 업데이트는 유지해야 합니다. 편의 기능을 추가하면서 이 원칙을 약화시키지 않아야 합니다.

기술 부채의 실제 규모

HTML은 3,913줄, app.py 1,158줄, operations.py 569줄입니다. 줄 수만으로 품질을 판단하지는 않지만 HTML·스타일·화면 로직·업무 기능이 한 파일에 집중되어 변경 영향 파악이 어렵습니다. 화면·공통 컴포넌트·API 클라이언트·업무 상태 정의를 점진적으로 분리하고, 신규 기능마다 핵심 업무 회귀 검사를 유지하는 편이 적절합니다.

> **현재 버전을 “완벽한 기업용 완제품”으로 표현하기는 어렵습니다. 반대로 기능이 없거나 검증 기반이 없는 시제품으로 보는 것도 정확하지 않습니다. 현업 기능이 축적된 경량 업무 시스템이며, 기업 운영 통제를 마무리해야 하는 단계입니다.**

16. 이번 검증 결과와 해석

통과 숫자를 운영 보증으로 확대하지 않음

검증	이번 결과	증명하는 범위
다운로드·ZIP	GET 성공 · 지정 SHA 일치 · CRC 정상	확인한 배포본의 동일성·손상 여부
MANIFEST	247개 파일 해시 일치	매니페스트에 기록된 파일 내용 일치. 전자서명 검증은 아님
Python 전체 검사	332개 통과 · 152.526초 · 실패/스킵 없음	패키지 테스트가 다루는 서버·권한·이관·복원·실패 경로
Node 검사	32개 통과 · 실패/스킵 없음	상태 판정·이력/통계 계산의 테스트 범위
최신 Chromium 시나리오	실행 완료 · 4개 결과 묶음 통과	모든 열 필터·정정·XLSX·화면 크기·초기화 경쟁 처리
맞춤 화면 크기	1920/1440/1024/768/390/320px	해당 대장 시나리오의 화면 넘침·조작 검사
추가 관찰 시험	백업·권한·재인증·API 노출 확인	10~14쪽의 재현 사실. 제품 테스트 통과 수에 합산하지 않음
단기 부하 검사	60/60 조회 성공	로컬5,000행/10클라이언트 조회 조건에 한함

기존 자동 검사가 다루는 중요한 실패 경로

지점·읽기 전용 권한 차단, 승인 위조 방지, DB 손상 보존, 트랜잭션 롤백, 중복·응답 유실 재시도, 최대2,000행 이관, 버전 충돌, 수기 정정 연결, 전체백업·복원, 첨부 권한·공지 삭제 후 접근 차단 등을 포함합니다. 이 결과는 기능 안정성의 긍정 근거입니다.

시험 환경 보정 기록

최초 Python 실행은 로컬 요청이 시험 환경의 외부 프록시로 전달되어 다수 403 Domain forbidden이 발생했습니다. 로컬 주소를 프록시 제외한 뒤 전체를 다시 실행한 최종 결과를 위에 기재했습니다. 이 최초 환경 오류를 제품 결함이나 통과로 계산하지 않았습니다. 실패 경로 테스트의 의도된 ERROR 로그도 최종 실패 수와 구별했습니다.

미검증을 남겨 두어야 하는 것

회사 Windows·Edge/WebView2·인증서 신뢰·방화벽, 실제 Oracle, 실제 회사 전체 데이터, 다일간 연속 운영, 장비 장애·랜섬웨어·OS 계정 변경, 전문 침투 시험은 통과로 표시하지 않았습니다. Windows CI 매트릭스 정의만으로 회사 PC 실기 검증을 대체하지 않습니다.

17. 회사 도입 승인 체크리스트

아래 조건을 충족한 뒤 병행 운영부터 시작

구분	확인할 내용	담당·합격 기준
사용 범위	보조 대장인지 공식 원장인지 결정	업무 책임자: 원장·회계와 YBY의 역할 문서화
운영 서버	PC·계정·고정 IP·절전/재부팅·실행/종료 권한	IT: 업무시간 가동·재기동·연락 체계 확인
접속	HTTPS, 서버/지점 로그인, 로그아웃·재접속·재부팅	IT+지점: 인증서 경고 없이 접속, 올바른 신뢰 지문 확인
권한	개인별 계정·최소 ALL·타 지점 차단·퇴사 처리	보안 담당: 권한표와 시험 결과 보관
비밀번호	타인 비밀번호 열람·자기 승인·세션 유지 정책	보안+업무: 위험 수용 또는 기능 제한 확정
백업	암호화·별도 위치·보존·오류/용량 감시	IT: 실제 자동 보관 성공과 접근 통제 확인
복구	별도 PC DB·첨부·계정·인증서 복구	IT+업무: 합계/건수/첨부 일치와 RPO/RTO 실측
정상·예외 업무	불출/사용/미사용/반려/취소/재보고/자기 결재	업무 담당: 실제 업무 사례 전후 수치·이력 일치
대량 이관	원본 행수·합계·중복·결측·반납·정정	데이터 담당: 대사표 승인, 원본·백업 보관
지점·카드 기준	회사 지점·조직·차량·카드 끝자리 중복	업무+개발: 누락 지점 없고 모호한 값은 검토 대기
통계·마감	공식 명세·보고서와 합계·사용 횟수 대사	회계: 월말 미확인 목록과 공식 수치 차이 설명
변경 관리	검증→백업→서버 중지→업데이트→확인→롤백	운영자: 적용 기록·복원 지점·담당자 보관

권고 운영 순서: 별도 시험 자료로 확인 → 실제 자료 복사본으로 인수 시험 → 기존 장부와 병행 → 미결 사항 해소 → 범위 확대. Oracle 수신은 별도 연동 검증 완료 후 활성화합니다.

> **보류 기준: 복구 시험 미실시, 백업 별도 보관 불가, 지점 권한 오류, 금액·건수 대사 불일치, 인증서 경고를 무시해야 접속되는 상태에서는 업무 확대를 중단하고 원인을 해결하십시오.**

18. 개선 순서와 최종 권고

기능 추가보다 운영 기반부터 정리

순서	해야 할 일	산출물
P1 정식 확대 전	복원 비밀번호 정책, ALL/자기 승인/세션 종료 정책 확정. 백업 암호화·분리 보관·새 PC 복구·회사 실기 시험	보안 예외/제한 설정, 복구 기록, 권한표, 인수 시험표
P2 운영 안정화	재인증 공통 제한, 백업 보존·용량 경보·가동 감시, 파일 검사·감사 외부 보관, 지점 마스터화	알림·운영 대시보드, 상태/보존 규정, 실패 경로 검사
P3 자료량 증가 전	서버 페이지 조회·부분 변경·인덱스 정비, 대형 HTML 분리, 혼합 부하·장기 운영 시험	성능 기준·결과, 모듈 구조, 유지보수 문서
별도 Oracle 단계	읽기 전용 뷰/SQL, 변경/철회·증분 수신, 연결 오류·재시도·카드/지점 모호성 처리	DB 대응표, 수신 점검표, 통합 시험 결과
공식 정산 체계 필요 시	카드사·회계 전표 대사, 마감·재개·수정 통제, 금액/통화·증빙 정책 확정	회계 요구 명세와 승인된 정산 기준

운영자가 평소 확인할 것

- 매일: 서버 가동·최근 백업·여유 공간·백업 경고·미반납/미정산/미확인 이관을 확인합니다.
- 정기적으로: 관리자·퇴사자·자기 승인·정정/삭제·대량 내보내기 내역과 별도 백업 복구 가능성을 점검합니다.
- 업데이트 전: 기존 실행 폴더의 자료로 전체백업을 만들고 서버를 정상 중지합니다. 새 프로그램만 교체한 뒤 로그인·한 건 업무·이력·첨부·합계를 확인합니다. DB를 다른 버전으로 임의 덮어쓰지 않습니다.
- 원격 사용: 사설 IP만으로 집에서 접속되지 않습니다. 회사 승인 VPN 등과 서버 가동이 필요하며, 공유기 포트 개방만으로 해결하려 하지 않습니다.

최종 결론

V4.1.20은 법인카드·하이패스·유류대카드 관리의 실제 흐름과 자료 추적 장치를 갖추고 있어, 제한된 사내 업무를 지원할 기반은 있습니다. 가장 잘된 점은 자료를 보호하며 정정·중복·충돌을 다루는 설계입니다. 가장 먼저 보완할 점은 비밀번호·백업 보호와 새 PC 복구, 관리자 통제, 운영 감시입니다.

회사의 실기·복구·대사 결과가 없는 상태에서는 전면 도입을 확정할 수 없습니다. 권고는 “통제 조건을 충족한 보조 업무 시범 운영”입니다. 이 조건을 완료하고 실제 업무 결과를 확인한 뒤 정식 운영 범위와 Oracle 통합 범위를 결정하십시오.

부록 A. 코드 근거와 재현 자료

배포본의 상대 경로·줄 번호. 수정 요청 시 이 번호를 사용

근거	경로·시작 줄	확인 내용
E01	app.py:35, 186, 329, 360, 598, 624, 692, 703, 785, 807, 880, 926	세션·백업·권한·CSP·계정 목록·재인증·비밀번호 조회
E02	security.py:7, 15, 48	PBKDF2 반복·암호 정책·클라이언트 계정 정리
E03	operations.py:34, 56, 136, 165, 343, 353, 491, 505	서버 한계·리다이렉트·첨부 권한·원자 작업·백업·자기 승인
E04	domain.py:6, 16, 36, 47, 93, 99	고정 지점·명세 검증·금액·일반 저장 보호
E05	backup_manager.py:14, 27, 30, 39, 48, 65	백업 내용·키 포함·압축·검증·복원
E06	storage.py:34, 47, 65; backup_tool.py:15, 28	전체 상태 처리·번호/기준일·오프라인 복원 잠금
E07	historical_import.py:78; settlement_workflow.py:19, 42	수기 정정·승인취소·재보고
E08	excel_intake.py:9, 21, 80; historical_import.py	파일/행 제한·원본 대응·금액·이력 이관
E09	static/excel-v4116.js; static/ledger-v4119.js	선택 초기화·저장 경쟁·대장 필터·정정 도구
E10	external_documents.py:1, 21; external_matching.py:82	Oracle 경계·문서 키·매칭 상태/권한
E11	templates/index.html:1536; windows_bootstrap.py:19, 63	고정 지점·MANIFEST/BOM 검증·프로그램 보존 업데이트
E12	fleet_cards.py:77; settlement_report.py	묶음 상태 전이·변경 전후·정산 보고서 복사
E13	templates/index.html:1553, 1599, 1617	번호 마스킹·업무 로컬 캐시 비활성·상태 폴링
E14	lan_setup.py:119, 156, 194; tools/create_lan_certificate.ps1:8; certificate_permissions.py:29	CA 생성/재사용·공개 클라이언트·갱신·ACL
E15	password_vault.py:9, 28, 40, 47; app.py:926	Windows DPAPI·비Windows Fernet·비밀번호 열람
E16	exports.py:8, 14	출력 제한·수식 아닌 문자열 셀
E17	static/vendor/NOTICE.md; .github/workflows/validate.yml	라이브러리 버전/출처·CI 정의

원본 배포:
https://github.com/ybyvip/yby/raw/b3220d0eb3038e6ff3454d552fc11ebe38b16e2c/downloads/yby_v4.1.20_full.zip

부록 B. 재현 방법·결과 해석·주의

합성 자료만 사용한 별도 실행 환경

검사 명령

ZIP 추출 폴더에서 실행: NO_PROXY=127.0.0.1,localhost no_proxy=127.0.0.1,localhost python -m unittest discover -s tests -v. Node: node --test tests/*.test.cjs. 브라우저: 같은 프록시 제외 조건에서 python tests/browser_v4120.py. 단기 부하: python tests/load_smoke.py. 이 명령은 이번 Linux 환경 기준이며 Windows 회사 실행 지침과는 구별합니다.

추가 관찰 시험의 구체적인 결과

관찰	결과	해석 제한
비로그인 bootstrap	200 · 합성 활성 계정3개 이름 반환	회사 실제 계정 수나 개인정보 유출 사건을 확인한 것은 아님
로그인 상태 재인증6회 실패	모두403 · 429 없음	로그인 API에는 별도 제한 존재. 공격 성공·전체 잠금 부재를 뜻하지 않음
허가된 서울 계정 카드 API	합성 전체 번호 반환	타 지점·무권한 자료 접근으로 판단하지 않음
ALL 계정 메뉴권한 비움	전체 자료 열람 유지	설계된 최고권한 범위. 무권한 승격 재현 아님
ZIP 암호화	암호화 플래그 없음 · DB SQLite 헤더 읽힘	체크섬/파일 권한은 존재. 저장매체 암호화는 별도
Linux 백업 비밀번호	ZIP 안 키로 합성 암호문 복원 가능	Windows DPAPI에 같은 결론을 적용하지 않음
접속 환경 백업	TLS·LAN 설정은 ZIP에 없음	현재 프로그램 업데이트가 이 파일을 보존하는 것과 백업 포함 여부는 별개

첨부 증거 파일

증거 묶음에는 최종 Python/Node/브라우저/단기 부하 로그, 합성 관찰 결과와 재현 스크립트, 패키지 해시·보고서 해시를 포함합니다. 회사 DB·비밀번호·개인 Excel·TLS 개인키는 포함하지 않습니다. 테스트 계정명과 암호 문자열은 임시 합성 환경 전용입니다.

해석과 책임 범위

우선도 “높음”은 회사 업무의 기밀성·복구·승인 신뢰에 미치는 영향을 기준으로 한 개선 우선순위입니다. CVSS 점수나 침해 발생 증거가 아닙니다. 잠재 위험·구현상의 제약·업무 정책·미검증 범위를 구분했습니다. 결함을 수정한 패키지를 이 보고서에 포함하거나 검토만으로 운영 승인을 확정하지 않았습니다.

다음 단계는 보고서의 도입 체크리스트를 회사 담당자와 확인하고, 우선 보완 범위와 승인 기준을 정하는 것입니다. 기존 기능을 전면 재작성하기보다 자료 보호 원칙을 유지하면서 통제 공백부터 보완하는 접근이 적절합니다.